Kuyumcu ERP — Durum ve Yol Haritası

Hazırlayan: **ByGatech A.Ş.** · Tarih: 14 Eylül 2026 · Sürüm: **3.0** (güncellendi)

1. Özet

Tarafınızdan teslim alınan yazılım, çalışan ancak **otomatik testi ve yasal uyum katmanı bulunmayan** bir durumdaydı. Bugün itibarıyla **591 otomatik test** çalışıyor ve tamamı başarılı.

Bu sürümde **yol haritasındaki 5 maddenin 5'i de tamamlandı**: uyum ekranları, 30.000 TL nakit belgeleme kontrolü, sentetik taş etiketleme, veri dışa aktarımı ve barkod/etiket basımı. Önceki raporda "sırada" görünen listede **bize ait iş kalmadı**; kalan maddelerin tamamı sizden gelecek bir sözleşme, teyit veya belgeye bağlı.

Ayrıca daha önce "ölçülmedi" diye bıraktığımız son başlık olan **yük davranışı ölçüldü** ve yazılımın her kimlik alanı için koruma kapısı olup olmadığı tek tek denetlendi — bu denetimde **üç gerçek açık bulundu ve kapatıldı**.

2. Devraldığımız Hâl

Ölçüt	Teslim aldığımızda	Bugün
Program kodu (satır)	6.774	**20.586**
Sistem işlev noktası	78	**105**
Modül	15	**20**
Veri tablosu	16	**23**
Otomatik test	**0**	**591 (tamamı başarılı)**
Veritabanı sürüm yönetimi	**yok**	**12 adım**
Yasal uyum katmanı	**yok**	**var**
Test kapsamı	**ölçülemezdi**	**%76,7**
Proje dokümantasyonu	**yok**	**34 belge, 13 diyagram**
Kullanıcı ekranı	12	**19**

> **Önemli tespit.** Teslim aldığımız kodda kanıtlanmış **6 kritik hata** vardı. En ciddisi, bir müşterinin kaydından başka bir müşterinin kasasına para yazılabilmesiydi — sistem bu işlemi hatasız kabul ediyordu. Bu ve diğer hatalar (çift kayıt, has altın hesabında işaret hatası) giderildi ve tekrarlamasını engelleyen testler yazıldı.

3. Ne Yaptık

3.1 Veri güvenliği ve müşteri ayrımı

- Her kuyumcunun verisi artık sistem düzeyinde ayrılmış durumda. Bir programcı kod yazarken filtreyi unutsa dahi başka bir işletmenin verisi görünmüyor.
- Bu korumanın gerçekten çalıştığı **korumayı bilerek devre dışı bırakarak** sınandı: 13 testin 11'i anında hata verdi, koruma geri konunca tümü düzeldi.
- Müşteri kimlik numaraları veritabanında **şifreli** tutuluyor; diskte açık metin olarak bulunmadığı doğrulandı.
- Kim neyi ne zaman okudu/yazdı kaydı tutuluyor (KVKK gereği).
- Şifre deneme sınırı, güvenli bağlantı zorunluluğu ve erişim kısıtlaması eklendi.
- **Yeni:** Tarayıcı güvenlik başlıkları ve içerik güvenlik politikası eklendi.
- **Yeni:** Kimlik doğrulama (giriş, şifre, oturum yenileme, çalıntı oturum tespiti) baştan sona test edildi.

3.2 MASAK yükümlülükleri

- 185.000 TL ve üzeri işlemlerde **kimlik tespiti olmadan işlem tamamlanamıyor** — uyarı verip geçmiyor, işlemi durduruyor.
- Tutar kademelerine göre işlem amacı ve beyan formu zorunluluğu.
- Şüpheli işlem bildirimi için **10 iş günü sayacı** — hafta sonu ve resmî tatilleri atlayarak hesaplıyor.
- 8 yıllık saklama yükümlülüğü: süre dolunca kayıt silinmiyor, yalnızca kimlik alanları maskeleniyor. Böylece hem denetim izi bozulmuyor hem kişisel veri gereğinden uzun tutulmuyor.
- Eşik tutarları ayar dosyasından okunuyor — mevzuat değişince **program değiştirmeye gerek yok**.

3.3 Vergi ve muhasebe

- **Gider pusulası** (VUK md.234): hurda alımında kimlik zorunlu, T.C. kimlik numarası doğrulaması, tutarın yazıyla yazılması, 7 günlük düzenleme süresi takibi.
- **Stopaj** (GVK md.94): satıcı tipine göre kesinti hesaplanıyor ve kasadan net tutar çıkıyor.
- **Gün sonu POS – fatura mutabakatı**: tahsilat ile kesilen fatura karşılaştırılıyor, fark ve faturasız işlemler listeleniyor.

3.4 Bu sürümde ölçülen ve düzeltilenler

Daha önce "ölçülmedi" diye bıraktığımız her alan ölçüldü:

Ölçüm	Sonuç
Test kapsamı	**%76,7** (çekirdek hesap katmanı %100)
Kod karmaşıklığı	Ortalama **3,0** — 409 fonksiyondan yalnız 8'i eşiğin üstünde
Programın açılış boyutu	**2,42 MB** (önceki raporda 7,53 MB yazmıştık — o ölçüm yanlış yöntemle yapılmıştı, gerçek rakam çok daha iyi)
Yedekten geri yükleme	**22 tablonun 22'si** birebir doğrulandı
Bağımlılık güvenliği	**0 güvenlik açığı** (yeni eklenen arşiv bileşeni dâhil)
Lisans uygunluğu	**0 kısıtlayıcı lisans**
Yük altında sunucu hatası	**921 istekte 0**

Bu ölçümler sırasında **dört kusur bulundu ve dördü de kapatıldı**:

Kusur	Etkisi
Kullanıcı IP'si yanlış okunuyordu	Sunucu önündeki yönlendirici nedeniyle tüm kullanıcılar aynı kişi gibi görünüyordu. Sonuç: bir kuyumcu kayıt olunca diğerleri saatlerce kayıt olamıyordu; erişim kayıtlarındaki IP bilgisi anlamsızdı.
MASAK kaydında doğrulama eksiği	Bir işletme, başka bir işletmenin kimlik tespiti kaydını kendi bildirimine bağlayabiliyordu. Bu kayıtlar sonradan değiştirilemediği için düzeltilemezdi.
Giriş sistemi test edilmemişti	Güvenliğin en kritik parçasının test kapsamı %6,7 idi. Şimdi %98.
Bir bileşende güvenlik açığı	Test aracının getirdiği bir bileşende orta seviye açık vardı. Aynı gün bulundu, aynı gün kapatıldı.

> **Bir bulguyu size ayrıca bildirmek isteriz.** Veri tutarlılığı taraması, geliştirme veritabanında **2 satır** bulunan bir kayıt buldu: bir işletmenin kaydı başka bir işletmenin kaydına bağlanmış durumda. İnceledik: bunlar **bizim kendi güvenlik testimizin kalıntısı** — 9 Eylül'de açığı kanıtlamak için oluşturduğumuz "Kurban Kasa" ve "Kurban Müşteri" kayıtları. Aynı tarama, tüm testler çalıştıktan sonra test veritabanında **tertemiz** sonuç veriyor; yani bugünkü yazılımda böyle bir açık yok. Kayıtları **silmedik** — güvenlik bulguları sessizce temizlenmez, raporlanır.

> **Test hakkında dürüst bir not.** Çalışma sırasında **4 gerçek hata** yakalandı ve dördü de yüzlerce başarılı otomatik testten geçmişti. Ancak gerçek veriyle canlı sunucuda çalışırken ortaya çıktılar — örneğin kasa defterinin yön bilgisini kaybetmesi ve stopajın kasadan düşülmemesi. Bu nedenle her adımı canlı ortamda gerçek veriyle ayrıca sınıyoruz. "Testler geçti" tek başına bizim için yeterli kanıt değil.

3.5 Bu sürümde tamamlananlar (yol haritasının 5 maddesi)

1) Uyum ekranları. MASAK ve gider pusulası işlevleri çalışıyordu ama ekranı yoktu. Artık var: şüpheli işlem ekrandan bildirilebiliyor, kimlik tespitleri ve süre takibi listeleniyor, gider pusulası **yazdırılabilir belge** olarak çıkıyor.

2) 30.000 TL nakit belgeleme kontrolü. Aynı gün aynı müşteriye yapılan nakit ödemelerin toplamı sınırı aşarsa **işlem duruyor** — uyarı verip geçmiyor. Gün sınırı Türkiye saatine göre hesaplanıyor.

> **Bu konuda bir araştırma yaptık ve sonucu size aynen aktarıyoruz.** "Vergi mükellefi olmayan vatandaştan hurda altın alımı bu kapsamda mı?" sorusunu birincil mevzuat kaynaklarından araştırdık. **Cevap: evet, kapsamda.** 18.10.2024 tarihli Resmî Gazete'de yayımlanan tebliğ ile mükellef olmayanlar (nihai tüketiciler dâhil) açıkça kapsama alındı. 30.000 TL üstü nakit hurda alımında ceza **hem kuyumcuya hem vatandaşa ayrı ayrı** kesiliyor ve ceza, işlem tutarının %10'undan az olmamak üzere asgari tutardan aşağı inmiyor — 31.000 TL'lik bir ödemede birinci sınıf tüccara **35.000 TL** ceza çıkabiliyor. Bu yüzden kapının "uyarı" değil "durdurucu" olmasında ısrar ettik.
>
> Ayrıca bir terminoloji düzeltmesi yaptık: yaygın olarak "VUK md. 459" denen düzenleme aslında bir *madde* değil, **459 Sıra No'lu Genel Tebliğ**dir. Belgelerimizde ve program içi uyarı metinlerinde bu düzeltildi.

3) Sentetik taş etiketleme. 24.06.2026 tarihli Resmî Gazete ile zorunlu oldu. Ürün kartına **taş kökeni** alanı eklendi; taş ağırlığı girilmiş bir ürün kökeni belirtilmeden **kaydedilemiyor ve satılamıyor**. "Sentetik / laboratuvar üretimi / yapay üretim" ibaresi etikete, ürün listesine ve etiket çıktısına otomatik basılıyor. Doğal ve yapay taşlar **ayrı kategoride** listeleniyor.

4) Veri dışa aktarımı. Sektörün en sık şikâyeti verinin programda kilitli kalmasıydı. Artık altı veri kümesi (cari, ürün, satış, fatura, kasa, gider pusulası) standart **CSV** olarak indirilebiliyor — Excel doğrudan açıyor, başka bir programa taşımak için bizden izin gerekmiyor.

> **Ama denetimsiz değil.** Dışa aktarım aynı zamanda bir sızdırma yüzeyidir. Bu yüzden: yalnız işletme sahibi yapabiliyor, **gerekçe yazmak zorunlu** (ve gerekçe denetim kaydına siliniemez şekilde işleniyor), kimlik bilgileri **varsayılan olarak maskeli** çıkıyor, maskesiz çıktı için ayrı bir onay metninin birebir yazılması gerekiyor, dosya **AES-256 ile şifreli** arşiv olarak iniyor ve parolası dosyayla aynı kanaldan verilmiyor. İndirme bağlantısı **10 dakika ömürlü ve tek kullanımlık**.

5) Barkod / etiket basımı. Her ürüne otomatik barkod üretiliyor; 50×30 mm etiketler A4'e dört sütun hâlinde basılıyor. Etiket, ürün adı ve ağırlık bilgisinin yanında **sentetik taş ibaresini de taşıyor** — yani iki yasal yük tek kâğıtta karşılanıyor.

> **Barkod konusunda bilerek yapmadığımız bir şey var.** Marketlerde gördüğünüz EAN-13 barkodu, GS1 adlı kuruluştan alınan bir **firma öneki** gerektirir. Bizde böyle bir önek yok. Rastgele bir önekle numara üretmek, fiilen **başka bir firmanın numara alanına yazmak** olurdu. Bunun yerine kayıt gerektirmeyen **Code 128** standardını kullandık; her el terminali okur. GS1 üyeliği alırsanız EAN-13 sonradan eklenebilir.
>
> Barkodun gerçekten okunabildiğini **varsaymadık**: ekrandaki çizimi geri okuyup bağımsız bir çözücüye verdik; çözülen metin ve sağlama değeri birebir tuttu.

3.6 Son ölçülmemiş başlık: yük davranışı

Daha önce "ölçülmedi" diye bıraktığımız tek başlık kalmıştı. Ölçüldü: 10 eşzamanlı kullanıcı, gerçek satış akışı dâhil.

Ölçüm	Sonuç
Ekran açılış / liste yanıtı (%95'lik dilim)	**25 ms**
Satış kaydı (%95'lik dilim)	**32 ms**
Sunucu hatası	**921 istekte 0**

Bu rakamlar bir geliştirme dizüstü bilgisayarında ölçülmüştür; üretim kapasitesi iddia edilmemektedir. Ölçümün amacı hız rekoru değil, yük altında **hata üretilmediğini** göstermektir. Testte güvenlik sınırları gevşetilmedi — gevşetip daha büyük bir rakam yazmak, gerçekte olmayan bir sayı üretmek olurdu.

3.7 Kimlik alanı denetimi — üç açık bulundu

Güvenlik sorumlumuzun talebiyle, veritabanındaki **36 bağlantı alanının tamamı** tek tek denetlendi: "Bu alan dışarıdan gelebiliyorsa, yazılmadan önce kontrol ediliyor mu?" Üç yerde kontrol **yoktu**:

Bulgu	Etkisi
Kasa açarken şube kontrolü yok	Var olmayan ya da başka bir işletmeye ait bir şube kimliğiyle kasa açılabiliyordu.
Kullanıcıya şube atarken kontrol yok	Daha ağırı. Atanan şube bilgisi kullanıcının oturum anahtarına giriyor ve sonra **satış kayıtlarına** yazılıyordu; yani yabancı bir şube kimliği defterlere sızabiliyordu.
Fatura okumasında ikinci koruma eksik	Genel koruma çalışıyordu, ama kuralımız "tek katman bırakma" der. İkinci koruma eklendi.

Üçü de kapatıldı ve **korumaları bilerek kaldırıp** testlerin kırmızıya döndüğü doğrulandı.

4. Proje Dokümantasyonu

Projenin uluslararası standartlara dayalı tam belge seti hazırlandı — **34 belge, 13 diyagram**. Herhangi bir firma teknik inceleme yaptığında görmek isteyeceği her başlık mevcut.

Belge grubu	Dayandığı standart	İçerik
Gereksinimler	ISO/IEC/IEEE 29148:2018	Yazılım ve paydaş gereksinimleri, mevzuat izlenebilirliği
Mimari	ISO/IEC/IEEE 42010:2022 · arc42 · C4	Mimari tanımı + **15 karar kaydı** (her kararın gerekçesi ve bedeli)
Kalite	ISO/IEC 25010:**2023**	9 kalite başlığı, 54 ölçülebilir hedef
Test	ISO/IEC/IEEE 29119-3:2021	Test politikası, planı ve tamamlama raporu
Güvenlik	OWASP ASVS 5.0.0 · ISO/IEC 27002:2022	17 başlıkta uygunluk matrisi + tehdit modeli
Süreç	ISO/IEC/IEEE 12207:2017	Yaşam döngüsü + **işletme kılavuzu (runbook)**
Proje yönetimi	PMBOK 8. baskı	Proje planı ve risk kaydı
Değerlendirme	—	Teknik öz-değerlendirme + teknik borç envanteri

Diyagramlar: veri modeli (genel + 4 konu alanı), sistem mimarisi (3 seviye), kullanım senaryoları, işlem akışı ve hurda alımı akışı.

> **İki nokta önemli.** Birincisi: veri modeli diyagramları **elle çizilmedi**, veritabanından otomatik üretiliyor — böylece şema değiştiğinde diyagram yalana dönüşmez. İkincisi: belge setinde **artık geçerli olmayan standartlar bilinçli olarak kullanılmadı**. İnternetteki hazır şablonların çoğu hâlâ geri çekilmiş standartlara dayanıyor; bunu bilen bir inceleyici için bu, güven artıran değil azaltan bir ayrıntıdır.

5. Sırada Ne Var

Önceki raporda sıralanan **5 maddenin 5'i de tamamlandı.**

#	İş	Durum
0 ✓	Test altyapısı ve denetim kaydının korunması	**TAMAMLANDI**
1 ✓	Uyum ekranlarının yapılması	**TAMAMLANDI — MASAK ekranı, gider pusulası listesi ve yazdırılabilir belge**
2 ✓	30.000 TL nakit belgeleme kontrolü	**TAMAMLANDI — aynı gün birikimli, işlemi durduruyor**
3 ✓	Sentetik taş etiketleme	**TAMAMLANDI — zorunlu köken alanı, etiket ibaresi, ayrı kategori**
4 ✓	Veri dışa aktarımı	**TAMAMLANDI — şifreli arşiv, tek kullanımlık bağlantı, denetim kaydı**
5 ✓	Barkod / etiket basımı	**TAMAMLANDI — otomatik barkod, A4 etiket sayfası**

Bizim tarafımızda kalan tek iş

İş	Neden henüz yapılmadı
Veritabanı bağlantı kısıtlarının kurulması	Tablolar arası bağlantıların veritabanı düzeyinde de zorlanması. Hazırlığı bitti: bağlantı taraması **0 kopuk kayıt** veriyor ve kimlik alanı denetimi tamamlandı. Tek engel aşağıdaki veri kararı.
Bekleyen karar: güvenlik testi kalıntısı 2 satır	Geliştirme veritabanındaki "Kurban Kasa / Kurban Müşteri" kayıtları (kendi sızma testimizin artığı). Bunlar durdukça kısıt kurulamaz. **Silinmesini onaylamanızı bekliyoruz** — güvenlik bulgusunu kendi başımıza silmeyiz.

Kapsam dışı bırakılanlar

Yasal zorunluluk olmadığı için bu aşamada bilinçli olarak yapılmadı: RFID, toptan satış modülü, imalat/atölye, tamirat takibi, personel ve prim yönetimi, masraf yönetimi, sertifika/katalog, mobil uygulama, e-ticaret entegrasyonu, iki adımlı doğrulama (MFA).

6. Neleri Yapamıyoruz — ve Neden

Aşağıdaki maddeler **yazılım eksikliğinden değil**, dış bağımlılıklardan kaynaklanıyor. Tahmine dayalı çözüm üretmeyi tercih etmiyoruz.

Yapılamayan	Sebep	Çözümü
e-Fatura / e-Arşiv	Özel entegratör firmayla sözleşme gerekiyor. Sözleşme olmadan entegratörün test ortamına gerçek fatura gönderilemez; taklit (sahte) bir bağlantı yazıp "yapıldı" demeyiz.	**Entegratör sözleşmesi**
MASAK'a gerçek bildirim gönderimi	MASAK'ın yazılımlar için bir bağlantı arayüzü (API) ve test sunucusu **bulunmuyor**. Bildirim yalnızca MASAK Online sistemine XML dosyası yüklenerek yapılıyor ve bu dosyanın şema tanımı kamuya açık değil. Sistem, bildirimi hazırlıyor ve süresini takip ediyor; gönderim adımı elle yapılıyor.	**MASAK'tan şema; işletme kaydı**
Stopaj oranlarının vergi borcuna işlenmesi	Oran doğrudan para hareketini etkiliyor. Mali müşavir teyidi olmadan rakam varsayamayız.	**Mali müşavir teyidi**
Fatura / e-fatura haddi	Araştırmada dört farklı ve birbiriyle çelişen rakama ulaşıldı. Hangisinin geçerli olduğu teyit edilmeden kodlanmadı; eşik ayar dosyasından okunacak şekilde hazırlandı.	**Mali müşavir teyidi**
KVKK aydınlatma metni	Hukuki metin. Sistem tarafı hazır, metnin kendisi hukuk danışmanınızdan gelmeli.	**Hukuk danışmanı**
KMTS biçim kontrolü	Kayıt alanı eklendi, ancak biçim şeması yayımlanmadığı için doğrulama yazılmadı. Not: Yaptığımız incelemede KMTS'nin perakende kuyumcuya doğrudan yükümlülük getirmediği, kapsamın rafinerilere yönelik olduğu görüldü.	**Şema yayını**

7. Sizden Beklediklerimiz

#	Konu	Neyi açar
1	e-Fatura özel entegratör sözleşmesi	e-Fatura / e-Arşiv adımının tamamı
2	Mali müşavir teyidi: fatura haddi ve hurda stopaj oranı	Vergi hesaplarının kesinleşmesi
3	Pilot işletme erişimi	Gerçek veriyle kabul testleri
4	Pilot işletmenin MASAK Online kaydı	Gerçek bildirim gönderimi
5	KVKK aydınlatma metni (hukuk danışmanı)	Yasal metnin sisteme girilmesi
6	**Şifre ve anahtarların yenilenmesi**	Teslim aldığımız kodda veritabanı şifresi ve güvenlik anahtarları sürüm geçmişine kaydedilmiş durumda. Dosyayı düzeltmek yetmiyor; geçmiş kayıt bu bilgileri saklamaya devam ediyor. Bu, geçmişi yeniden yazan bir işlem olduğu için sizin kararınıza bırakıldı.
7	**Güvenlik testi kalıntısı 2 satırın silinmesi onayı**	Geliştirme veritabanındaki kendi sızma testimizin artığı. Silinmeden veritabanı bağlantı kısıtları kurulamıyor. Güvenlik bulgusunu kendi başımıza silmeyiz — onayınızı bekliyoruz.
8	Yazılımın mülkiyet/devir belgesi	Kod sahipliğini gösteren bir belge bulunmuyor. Bu, her ciddi görüşmede sorulan ilk başlıklardandır.

8. Değerlendirme

Bizim yapabileceğimiz işler bitti. Teslim aldığımız yazılımda hiç otomatik test yoktu ve kanıtlanmış 6 kritik hata bulunuyordu. Bugün **591 test**, otomatik kod denetimi, iki katmanlı veri güvenliği, ölçülmüş yük davranışı ve standartlara dayalı **34 parçalık belge seti** mevcut.

Yol haritasındaki **5 maddenin 5'i de tamamlandı**. Bizim tarafımızda kalan tek teknik iş, sizin bir onayınıza bağlı (güvenlik testi kalıntısının silinmesi). Geriye kalan her şey — e-Fatura, MASAK bildirim gönderimi, vergi oranlarının teyidi, hukuki metinler — **dış bağımlılıktır ve tahminle kapatılmaz**.

Ürün, tek dükkân ve 2–3 şubeli perakende kuyumcu için **pilot kullanıma sunulabilir** durumdadır. Rakiplerle tam kıyaslanabilir olgunluk için eksik olan yasal katman değil, kapsam dışı bırakılan ticari modüllerdir (toptan, imalat, mobil).

> **Kendi çalışmamız hakkında dürüst bir not.** Bu sürümde bulduğumuz hataların bir kısmı **yüzlerce başarılı testten geçmişti**. Örneğin barkod, ekranda hiç çizilmiyordu: sayı biçimlendirmesi Türkçe virgül kullandığı için tarayıcı çizimi okuyamıyordu — ama testler İngilizce biçimde koştuğu için **yeşildi**. Bir diğeri: yasal ibare etikete "SENTETIK" diye basılıyordu, doğrusu "SENTETİK". Bu yüzden her adımı canlı ortamda gerçek veriyle ayrıca sınıyoruz ve raporlarımızda "testler geçti" ifadesini tek başına kanıt saymıyoruz.